Duale Hochschule Baden-Württemberg Mannheim

Studienarbeit

Konzeption, Entwicklung und Implementierung eines datengetriebenen Neo-Brokers im Rahmen agiler Softwareentwicklung

Studiengang Informatik

Studienrichtung Cyber Security

Verfasser:	Nathan Becker, Dustin Döhring
Matrikelnummer:	4335441, 2265248
Kurs:	TINF23CS2
Betreuer:	Jürgen Schultheis
Bearbeitungszeitraum:	14.10.2025 – 14.04.2026
Eingereicht:	14.04.2026

Inhaltsverzeichnis

1 Einleitung **1**

1.1 Relevanz 1

1.2 Motivation 4

1.3 Problemraumbeschreibung 6

1.4 Technische und Organisatorische Umgebung 8

2 Strukturierte Aufgabenstellung **9**

3 Methoden und Verfahren **21**

4 Theoretische und Technische Grundlagen **22**

5 Bearbeitung der strukturierten Aufgabenstellung **23**

6 Objektivierter Ergebnisteil **157**

7 Diskussion **158**

8 Ausblick **159**

Abbildungsverzeichnis

Tabellenverzeichnis

Abstract

Akronyme

1 Einleitung

Dieses Kapitel behandelt die Einleitung der Arbeit und dient der strukturierten Hinführung zum Untersuchungsthema. Zunächst wird die Relevanz des Themas im fachlichen und organisatorischen Kontext dargestellt. Darauf aufbauend wird die Motivation für die Durchführung der Arbeit erläutert. Anschließend erfolgt eine präzise Beschreibung der zugrunde liegenden Problemstellung. Abschließend wird die technische sowie organisatorische Umgebung skizziert, in der die Arbeit verortet ist.

1.1 Relevanz

Die fortschreitende Digitalisierung und der Aufstieg von Neobrokern haben den Zugang zum Aktienmarkt verändert. Durch technologische Innovationen, automatisierte Prozesse und benutzerfreundliche mobile Anwendungen ist Investieren heute so einfach, kostengünstig und barrierearm wie nie zuvor. Mit wenigen Klicks können Menschen weltweit an der Entwicklung der Finanzmärkte teilhaben und ihre persönliche Vermögensbildung aktiv mitgestalten. Der niedrigschwellige Zugang hat zu einer deutlichen Demokratisierung des Investierens geführt und neue Anlegergruppen erschlossen, die zuvor aufgrund hoher Gebühren, komplexer Strukturen oder mangelnder Informationsangebote kaum Berührungspunkte mit dem Kapitalmarkt hatten. Besonders im Kontext der privaten Altersvorsorge gewinnt dieses Thema zunehmend an Bedeutung, da traditionelle Anlageformen aufgrund niedriger Zinsen und wirtschaftlicher Unsicherheiten an Attraktivität verloren haben. Die Kombination aus einfachen Einstiegsmöglichkeiten, geringen Transaktionskosten und hoher Transparenz unterstreicht die zunehmende Bedeutung digitaler Investmentplattformen im Rahmen moderner Vermögensbildung.

So zeigt auch eine Erhebung des Deutschen Instituts für Vermögensbildung und Alterssicherung (DIVA), dass die Verbreitung von Wertpapierdepots in der Bevölkerung ein beachtliches Niveau erreicht hat: Mehr als die Hälfte der Befragten (51,7 %) verfügt demnach über ein oder mehrere Depots, wobei 43,0 % dieser Personen (auch) einen Neobroker nutzen. Besonders auffällig ist die überdurchschnittlich hohe Nutzung digitaler Broker in den jüngeren Altersgruppen: 59,1 % der unter 29-Jährigen und 58,1 % der unter 49-Jährigen greifen auf entsprechende Angebote zurück.

Ein Blick auf die Zeitreihe der Deutschen Bundesbank verdeutlicht klar die Dynamik dieser Entwicklung. Die Grafik zeigt, dass die Zahl der Wertpapierdepots privater Haushalte über viele Jahre relativ stabil blieb und sogar leicht rückläufig war. Erst ab 2019 setzt ein deutlicher struktureller Wandel ein, der sich ab 2020 weiter beschleunigt. Dieser Anstieg fällt zeitlich sowohl mit der Einführung moderner Neobroker wie Trade Republic (2019) und Scalable Capital (2020) als auch mit den Bedingungen der Corona-Pandemie zusammen. Während die Pandemie durch vermehrte digitale Aktivitäten und ein gestiegenes Interesse an privater Finanzplanung eine zusätzliche Verstärkung bewirkte, reduzierten die Neobroker gleichzeitig erheblich die Hürden für den Kapitalmarktzugang. Insbesondere die Kombination aus intuitiven Apps, sehr niedrigen oder vollständig entfallenden Ordergebühren und einem stark vereinfachten Onboarding-Prozess dürfte dazu beigetragen haben, dass Millionen neuer Anleger erstmals ein Depot eröffneten. Die Grafik belegt daher nicht nur einen kurzfristigen Effekt, sondern markiert einen strukturellen Wandel in der Anlegerkultur Deutschlands. Trotz dieser positiven Entwicklung bleibt jedoch eine entscheidende Lücke bestehen: Während der Handel selbst inzwischen weitgehend vereinfacht und automatisiert ist, mangelt es an integrierten, benutzerfreundlichen Lösungen für eine fundierte Marktanalyse. Bestehende Anwendungen beschränken sich häufig auf Basisfunktionen oder liefern Informationen nur in Fragmenten – beispielsweise über Kursentwicklungen, Unternehmensdaten oder Nachrichtenfeeds. Eine tiefgehende, ganzheitliche Analyse des Marktes, die verschiedene Informationsquellen zusammenführt und verständlich aufbereitet, ist für Privatanleger nach wie vor schwer zugänglich.

Hinzu kommt, dass viele Privatanleger erst dann von relevanten Marktbewegungen oder wirtschaftlichen Trends erfahren, wenn die entscheidenden Gewinne bereits realisiert wurden. Die Informationsflut ist groß, aber verstreut und oft nur mit erheblichem Zeitaufwand zu durchdringen. Dies erschwert es insbesondere Einsteigern, aber auch erfahrenen Anlegern, informierte und strategisch durchdachte Entscheidungen zu treffen.

Auch im Kontext des demografischen Wandels ist die zunehmende Bedeutung digitaler Investmentlösungen zu betrachten. Mit der Alterung der Gesellschaft und dem zunehmenden Druck auf umlagefinanzierte Rentensysteme sind immer mehr Menschen gezwungen, ihre Altersvorsorge eigenständig und kapitalmarktbasiert zu organisieren. Gleichzeitig rücken längere Erwerbsbiografien und ein wachsender Zeitraum der Ruhestandsfinanzierung in den Fokus. Dies erhöht nicht nur die Bedeutung langfristiger und informierter Investitionsentscheidungen, sondern verstärkt auch den Bedarf an verständlichen, integrierten Analyse- und Entscheidungshilfen für Privatanleger. Gerade vor diesem Hintergrund wird deutlich, dass der vereinfachte Zugang zum Handel allein nicht ausreicht, um nachhaltige Vermögensbildung zu ermöglichen.

1.2 Motivation

Die zunehmende Verbreitung digitaler Investmentplattformen hat den Zugang zum Aktienhandel erheblich vereinfacht, während professionelle Marktanalysen weiterhin nur über komplexe und oft schwer zugängliche Spezialwerkzeuge verfügbar sind. Dadurch entsteht eine deutliche Lücke zwischen intuitiven Handels-Apps und anspruchsvollen Analyseumgebungen, die viele Privatanleger vor Herausforderungen stellt. Diese Diskrepanz bildet die zentrale Motivation des vorliegenden Projekts. Ziel ist es, eine Plattform zu entwickeln, die Benutzerfreundlichkeit mit analytischer Tiefe verbindet und es Nutzerinnen und Nutzern ermöglicht, fundierte Informationen ohne technische oder fachliche Barrieren zu nutzen. Durch verständliche Visualisierungen, strukturierte Datenaufbereitung und nachvollziehbare Analyseprozesse soll eine Anwendung entstehen, die sowohl den Handel effizienter gestaltet als auch langfristig zur finanziellen Bildung beiträgt.Die Plattform soll damit eine Brücke zwischen Einsteigerfreundlichkeit und professioneller Marktanalyse schlagen und Anlegerinnen und Anleger in ihrer selbstbestimmten Vermögensplanung unterstützen.

Die Wahl dieses Projekts ist zudem durch die Verbindung zweier Themenfelder motiviert, die sowohl in der Ausbildung als auch im praktischen Kontext eine zentrale Rolle spielen: Softwareentwicklung und Kapitalmarktanalyse. Die Kombination aus technischem Interesse an der Entwicklung interaktiver Anwendungen und inhaltlichem Interesse an finanzwirtschaftlichen Fragestellungen bietet die Möglichkeit, ein reales Anwendungsproblem ganzheitlich zu bearbeiten.

Die Entscheidung für eine technische Umsetzung anstelle eines rein analytischen oder konzeptionellen Ansatzes beruht auf dem Anspruch, den gesamten Entwicklungsprozess abzubilden. Neben der inhaltlichen Analyse sollen Konzeption, Implementierung und praktische Erprobung einer Anwendung berücksichtigt werden, um sowohl funktionale als auch nutzerbezogene Anforderungen nachvollziehbar umzusetzen. Dadurch wird eine umfassende Betrachtung ermöglicht, die theoretische Überlegungen mit einer konkreten, lauffähigen Lösung verbindet.

Darüber hinaus ergibt sich die Motivation aus dem praktischen Anspruch, ein reales Problemfeld durch eine softwarebasierte Lösung zu adressieren. Anstelle einer rein theoretischen Betrachtung soll im Rahmen dieser Arbeit eine prototypische Anwendung entstehen, die konzeptionelle Überlegungen unmittelbar in ein funktionales System überführt. Dies ermöglicht es, technische, konzeptionelle und nutzerbezogene Anforderungen ganzheitlich zu betrachten und deren Zusammenspiel in der Praxis zu evaluieren.

1.3 Problemraumbeschreibung

Der vorliegende Problemraum betrifft eine wachsende Gruppe von Akteuren, die in besonderem Maße von der Digitalisierung des Wertpapierhandels beeinflusst wird. Dazu zählen vor allem junge Menschen und Neuanleger, die erstmals Zugang zum Aktienmarkt erhalten, ebenso wie Personen aus bildungsferneren Schichten, die aufgrund sprachlicher oder didaktischer Barrieren Schwierigkeiten haben, komplexe Finanzinformationen zu verstehen. Auch Nutzerinnen und Nutzer mit praktischer Tradingerfahrung, jedoch ohne tiefere finanzwirtschaftliche Kenntnisse, sind betroffen, da sie zwar bereits handeln, aber häufig keine ausreichende fachliche Grundlage besitzen. Darüber hinaus stellt die zunehmende Digitalisierung ältere Generationen vor zusätzliche Herausforderungen, weil fehlende digitale Kompetenz die Nutzung moderner Handelsanwendungen erschwert.

Trotz der hohen Verfügbarkeit leicht zugänglicher Handelsplattformen bestehen erhebliche Defizite im Bereich der Wissensvermittlung, Analyseunterstützung und Transparenz. Während Neobroker den Zugang zum Markt stark erleichtern, bleibt der Zugang zu qualitativ hochwertigen Informationen, Analysewerkzeugen und Bildungsinhalten vielerorts eingeschränkt oder ist an kostenpflichtige Angebote gebunden, die für bestimmte Bevölkerungsgruppen nicht zumutbar sind. Es entsteht ein struktureller Widerspruch: Einerseits werden breite Bevölkerungsschichten zum Investieren ermutigt – oftmals durch intensive Marketingkampagnen mit hohen Gewinnversprechen und minimalen Risikohinweisen –, andererseits fehlt es diesen Nutzergruppen an den notwendigen Instrumenten und Kompetenzen, um fundierte Entscheidungen zu treffen. Diese Diskrepanz verschärft bestehende Ungleichheiten, denn während der Zugang zum Markt technisch niedrigschwellig ist, bleibt der Zugang zu Wissen und Analysefähigkeit weiterhin hochschwellig. Die Folge ist nicht selten ein Investitionsverhalten, das von Trends, Emotionen oder Fehlinformationen geprägt ist, was wiederum zu finanziellen Verlusten führt – ein Umstand, von dem Plattformbetreiber aufgrund gebührenbasierter Geschäftsmodelle indirekt sogar profitieren können.

Nachweisbare Lücken zeigen sich insbesondere in der fehlenden Integration von Bildungs- und Analysefunktionen innerhalb bestehender Brokerage-Anwendungen, in der unzureichenden Aufbereitung komplexer Finanzdaten sowie in der mangelnden Unterstützung bei der Einschätzung von Risiken. Während professionelle Analysewerkzeuge zwar existieren, sind sie häufig teuer, technisch anspruchsvoll oder für Einsteiger unverständlich aufbereitet. Damit bleibt ein wesentlicher Aspekt ungeklärt: Wie kann finanzwirtschaftliches Fachwissen so vermittelt und Analysefunktionen so bereitgestellt werden, dass sie unterschiedlichen gesellschaftlichen Milieus zugänglich sind, ohne dass hohe Kosten oder technische Hürden entstehen? Ebenso stellt sich die Frage, wie bestehende Plattformmodelle, die primär auf Umsatzgenerierung ausgerichtet sind, so transformiert werden können, dass sie neben der Bedienfreundlichkeit auch echte finanzielle Aufklärung ermöglichen. Aus diesem Problemfeld ergibt sich ein übergeordnetes Ziel: die Entwicklung eines Systems, das den einfachen Zugang zum Investieren mit qualifizierten, verständlichen und zugleich leistungsfähigen Analyse- und Bildungswerkzeugen verbindet. Das Projekt trägt dazu bei, die bestehenden Schwierigkeiten zwischen erfahrungsarmen Einsteigern und professionellen Marktteilnehmern besser zu verstehen und Lösungen zu entwickeln, die diese Lücke nachhaltig schließen. Trotz der niedrigen Einstiegshürden im modernen Aktienhandel besteht weiterhin das Problem des informierten Investierens, da viele Anbieter ihre Nutzerinnen und Nutzer weder ausreichend aufklären noch ihnen die Werkzeuge zur Verfügung stellen, die sie für fundierte Entscheidungen benötigen. Die geplante Anwendung setzt genau hier an: Sie zielt darauf ab, Nutzer durch integrierte Analysefunktionen, hochwertige Informationsmaterialien und intuitive Risikobewertungen zu befähigen, auf Basis von Wissen und nicht aufgrund von Intuition oder Marktgeräuschen zu handeln. Langfristig soll so ein nutzerzentriertes, transparentes und aufklärungsorientiertes System entstehen, das die bestehenden Defizite im Bereich Bildung, Informationszugang und Entscheidungsunterstützung adressiert und einen Beitrag zu einem nachhaltigeren und verantwortungsvolleren Anlegerverhalten leistet.

1.4 Technische und Organisatorische Umgebung

2 Strukturierte Aufgabenstellung

Dieses Kapitel beschreibt die funktionalen und nicht-funktionalen Anforderungen an die entwickelte Plattform in strukturierter Form. Ziel ist eine systematische Darstellung der vorgesehenen Funktionen sowie der qualitativen Anforderungen an Gestaltung, Sicherheit und Nutzung. Die Gliederung ermöglicht eine klare Zuordnung zwischen fachlichen Zielsetzungen, technischen Umsetzungen und gestalterischen Aspekten und dient zugleich als Grundlage für Planung, Implementierung und spätere Bewertung der Systemfunktionen. Darüber hinaus bildet die strukturierte Aufgabenstellung die methodische Basis des wissenschaftlichen Arbeitens, da sie Transparenz, Nachvollziehbarkeit und eine konsistente Ableitung der späteren Analyse- und Umsetzungsschritte gewährleistet.

1 Kern Funktionen

Die Kernfunktionen umfassen die fachlichen Hauptfunktionen der Plattform und bilden die Grundlage für alle weiteren Analyse-, Darstellungs- und Interaktionsmechanismen. Sie adressieren die Verarbeitung, Analyse und Aufbereitung finanzbezogener Daten sowie die Bereitstellung entsprechender Auswertungen für Nutzer. Der Fokus liegt auf funktionaler Vollständigkeit, fachlicher Korrektheit und einer konsistenten Datenbasis.

1.1 Portfoliomanagement

1.1.1 Implementierung einer Funktion zur Erstellung, Bearbeitung und Löschung individueller Benutzerportfolios.

1.1.2 Entwicklung einer Ansicht zur Anzeige aller im Portfolio enthaltenen Positionen einschließlich ihrer relativen Gewichtungen.

1.1.3 Umsetzung einer Darstellung zur Visualisierung historischer Performance- und Wertentwicklungen von Portfolios.

1.2 Marktdaten

1.2.1 Anbindung externer Datenquellen zum Abruf aktueller und historischer Kurs- und Zeitreihendaten.

1.2.2 Implementierung einer Normalisierung und Zwischenspeicherung der abgerufenen Marktdaten.

1.2.3 Realisierung einer automatisierten Aktualisierung der Marktdaten in definierten Intervallen.

1.3 Nachrichten & Sentiment

1.3.1 Integration externer Nachrichtenquellen zur Anzeige relevanter Informationen zu Finanzinstrumenten und Märkten.

1.3.2 Aggregation und Bereitstellung von Sentiment-Bewertungen aus externen Datenquellen.

1.3.3 Implementierung von Filtermechanismen zur themen-, markt- und asset-bezogenen Eingrenzung der Inhalte.

1.4 Fundamentalanalyse

1.4.1 Berechnung fundamentaler Kennzahlen auf Basis interner und externer Datenquellen.

1.4.2 Umsetzung historischer Vergleiche fundamentaler Kennzahlen über definierte Zeiträume.

1.4.3 Darstellung der Analyseergebnisse in strukturierter Form mittels Tabellen und Diagrammen.

1.5 Alerts & Benachrichtigungen

1.5.1 Implementierung einer Funktion zur Definition benutzerindividueller Alert-Regeln.

1.5.2 Entwicklung einer Verwaltungsoberfläche zur Übersicht und Pflege bestehender Alerts.

1.5.3 Umsetzung eines Mechanismus zur Auslösung systeminterner Benachrichtigungen bei Erreichen definierter Bedingungen.

1.6 Technische Analyse

1.6.1 Implementierung der Berechnung gängiger technischer Indikatoren.

1.6.2 Visualisierung der Ergebnisse technischer Analysen in geeigneten Chart-Darstellungen.

1.6.3 Ermöglichung der kombinierten Nutzung mehrerer technischer Indikatoren innerhalb einer Analyse.

1.7 Quantitative Analyse & Screening

1.7.1 Entwicklung einer Funktion zur Definition regelbasierter Screening-Kriterien.

1.7.2 Umsetzung quantitativer Analyseverfahren auf Basis definierter Regeln.

1.7.3 Implementierung eines Vergleichs und einer Auswertung der generierten Analyseergebnisse.

1.8 Makro- & Marktumfeld

1.8.1 Integration makroökonomischer Kennzahlen aus externen Datenquellen.

1.8.2 Bereitstellung übersichtlicher Marktüberblicke zur Kontextualisierung einzelner Analysen.

1.8.3 Umsetzung zeitlicher Vergleiche makroökonomischer und marktbezogener Daten.

2 User Interface & Interaction Design

Dieses Unterkapitel beschreibt Anforderungen an die Gestaltung der Benutzeroberfläche und die Nutzerinteraktion. Ziel ist eine konsistente, intuitive und effiziente Bedienbarkeit der Plattform über alle Funktionen hinweg. Neben strukturellen Aspekten der Informationsarchitektur werden auch Anforderungen an Responsiveness, Performance und Benutzerführung berücksichtigt.

2.1 Kernflows

2.1.1 Gestaltung konsistenter Navigationspfade zwischen den zentralen Kernfunktionen der Plattform.

2.1.2 Definition einheitlicher Seitenabfolgen innerhalb der Kernnutzungsflüsse.

2.1.3 Reduktion unnötiger Interaktionsschritte zur Optimierung der Nutzerführung.

2.2 Informationsarchitektur

2.2.1 Strukturierung der Inhalte in klar abgegrenzte und logisch aufgebaute Bereiche.

2.2.2 Implementierung einer eindeutigen und konsistenten Navigationsstruktur.

2.2.3 Vermeidung redundanter oder widersprüchlicher Darstellungen innerhalb der Benutzeroberfläche.

2.3 Responsiveness eventuell Reaktionsfähigkeit

2.3.1 Sicherstellung der Nutzbarkeit der Plattform auf Desktop-, Tablet- und mobilen Endgeräten.

2.3.2 Anpassung von Layouts und Interaktionselementen an unterschiedliche Bildschirmgrößen.

2.3.3 Überprüfung der vollständigen Sicht- und Bedienbarkeit aller Inhalte auf verschiedenen Endgeräten.

2.4 Charting

2.4.1 Implementierung interaktiver Charts zur grafischen Analyse von Daten.

2.4.2 Sicherstellung einer einheitlichen Skalierung und konsistenten Darstellung der Visualisierungen.

2.4.3 Gewährleistung einer korrekten Abbildung der zugrunde liegenden Daten in allen Charts.

2.5 Benutzerfreundlichkeit & Performance

2.5.1 Optimierung der Reaktionszeiten der Benutzeroberfläche.

2.5.2 Reduktion unnötiger Lade- und Wartezeiten.

2.5.3 Sicherstellung einer stabilen und fehlerfreien Darstellung auch bei hoher Systemlast.

2.6 Barrierefreiheit & Lesbarkeit

2.6.1 Umsetzung einer kontrastreichen Darstellung aller Inhalte.

2.6.2 Ermöglichung skalierbarer Schriftgrößen ohne Funktionsverlust.

2.6.3 Verwendung verständlicher und eindeutiger Beschriftungen in der Benutzeroberfläche.

2.7 Guided UX

2.7.1 Implementierung von Tooltips zur kontextbezogenen Unterstützung der Nutzer.

2.7.2 Bereitstellung erklärender Hinweise zu Funktionen und Nutzungspfaden.

2.7.3 Umsetzung einer schrittweisen Unterstützung bei komplexeren Interaktionen.

2.8 Internationalisierung

2.8.1 Implementierung einer Umschaltfunktion zwischen unterstützten Sprachen.

2.8.2 Anzeige lokalisierter Texte und Inhalte entsprechend der Spracheinstellung.

2.8.3 Sicherstellung der konsistenten Funktionalität unabhängig von der gewählten Sprache.

3 Informationsdarstellung & Risikokommunikation

Der Schwerpunkt dieses Unterkapitels liegt auf der verständlichen und kontextbezogenen Darstellung von Informationen, Analyseergebnissen und Risiken. Ziel ist es, Nutzer bei der Interpretation der bereitgestellten Daten zu unterstützen und potenzielle Fehlinterpretationen durch geeignete Hinweise, Warnmeldungen und Kontextinformationen zu reduzieren.

3.1 Darstellung von Marktdaten & Analysen

3.1.1 Implementierung einer konsistenten Visualisierung von Marktdaten und Analyseergebnissen.

3.1.2 Kontextualisierung von Kennzahlen zur Unterstützung einer eindeutigen Interpretation.

3.1.3 Sicherstellung einer einheitlichen Darstellungslogik über alle Analyseansichten hinweg.

3.2 Nachrichten- & Sentimentdarstellung

3.2.1 Trennung von Nachrichten, Analysen und Meinungen innerhalb der Darstellung.

3.2.2 Eindeutige Kennzeichnung externer Inhalte als solche.

3.2.3 Kontextbezogene Präsentation von Nachrichten- und Sentimentinformationen.

3.3 Risikohinweise & Warnmeldungen

3.3.1 Einbindung von Risikohinweisen im Kontext analytischer Auswertungen.

3.3.2 Anzeige von Warnmeldungen bei unvollständigen oder unsicheren Daten.

3.3.3 Bereitstellung von Hinweisen auf externe Abhängigkeiten und Datenquellen.

3.4 Fehlerzustände & Systemmeldungen

3.4.1 Implementierung einheitlicher und verständlicher Fehlermeldungen.

3.4.2 Trennung von nutzerrelevanten Informationen und internen Systemdetails.

3.4.3 Kontextbezogene Anzeige von Systemmeldungen zur Unterstützung der Nutzerinteraktion.

3.5 Bestätigungs- & Hinweisstufen

3.5.1 Umsetzung von Bestätigungsmechanismen vor potenziell kritischen Nutzeraktionen.

3.5.2 Definition und Implementierung unterschiedlicher Hinweisstufen.

3.5.3 Sicherstellung einer konsistenten Interaktionslogik bei Bestätigungen und Hinweisen.

4 Vertrauen, Transparenz & UX-Security

Dieses Unterkapitel adressiert Anforderungen zur Stärkung von Vertrauen, Transparenz und Sicherheit aus Sicht der Nutzerinteraktion. Sicherheitsrelevante Zustände und Aktionen sollen nachvollziehbar, konsistent und verständlich kommuniziert werden, ohne interne Systemdetails offenzulegen. Der Fokus liegt auf einer klaren und nutzerzentrierten Sicherheitswahrnehmung.

4.1 Sicherheit & Vertrauen

4.1.1 Darstellung sichtbarer Sicherheitsindikatoren innerhalb der Benutzeroberfläche.

4.1.2 Umsetzung konsistenter Rückmeldungen bei sicherheitsrelevanten Aktionen.

4.1.3 Vermeidung widersprüchlicher oder irreführender UI-Signale im Sicherheitskontext.

4.2 Transparenz sicherheitsrelevanter Aktionen

4.2.1 Anzeige verständlicher Hinweise bei sicherheitsrelevanten Änderungen.

4.2.2 Rückmeldung an Nutzer bei kritischen sicherheitsbezogenen Aktionen.

4.2.3 Umsetzung zeitnaher Benachrichtigungen ohne Offenlegung interner Systemdetails.

4.3 Auditierbarkeit aus Nutzersicht

4.3.1 Bereitstellung einer Einsicht in sicherheitsrelevante Nutzeraktionen.

4.3.2 Zeitliche Einordnung und Nachvollziehbarkeit sicherheitsbezogener Ereignisse.

4.3.3 Beschränkung der Einsicht auf eigene nutzerbezogene Aktivitäten.

4.4 Feature- & Zugriffstransparenz

4.4.1 Darstellung der für den jeweiligen Nutzer freigeschalteten Funktionen.

4.4.2 Erläuterung eingeschränkter oder nicht verfügbarer Features.

4.4.3 Konsistente Visualisierung von Berechtigungen und Zugriffsumfängen.

4.5 Personalisierung & Sichtbarkeit von Sicherheitsfunktionen

4.5.1 Umsetzung einer personalisierbaren Anzeige sicherheitsrelevanter Hinweise.

4.5.2 Bereitstellung personalisierter sicherheitsbezogener Benachrichtigungen.

4.5.3 Sicherstellung einer konsistenten Sicherheitsdarstellung unabhängig von Personalisierungen.

5 Plattformsicherheit & Zugriffskontrolle

In diesem Unterkapitel werden Anforderungen an die technische Absicherung der Plattform sowie an die Zugriffskontrolle und Nutzerauthentifizierung beschrieben. Ziel ist es, einen sicheren, kontrollierten und nachvollziehbaren Zugriff auf Funktionen und Daten zu gewährleisten. Neben Authentifizierung und Autorisierung werden auch Aspekte der Sitzungsverwaltung, Schnittstellensicherheit und Sicherheitsüberwachung berücksichtigt.

5.1 Authentifizierung

5.1.1 Implementierung eines sicheren Anmeldeverfahrens für Nutzer.

5.1.2 Verifikation von Nutzeridentitäten vor dem Zugriff auf personalisierte Funktionen.

5.1.3 Absicherung des Authentifizierungsprozesses gegen Missbrauch.

5.2 Autorisierung & Rollenmodelle

5.2.1 Umsetzung einer rollenbasierten Zugriffskontrolle.

5.2.2 Definition funktions- und datenbezogener Berechtigungen.

5.2.3 Zentrale Durchsetzung der Autorisierungslogik im System.

5.3 Sitzungs- & Zugriffssicherheit

5.3.1 Implementierung einer sicheren Verwaltung aktiver Sitzungen.

5.3.2 Zeitliche Begrenzung von Zugriffen auf personalisierte Funktionen.

5.3.3 Sicherstellung einer kontrollierten und sicheren Beendigung von Sitzungen.

5.4 Schnittstellensicherheit

5.4.1 Absicherung interner und externer Programmierschnittstellen.

5.4.2 Validierung eingehender Anfragen vor deren Verarbeitung.

5.4.3 Kontrolle und Einschränkung zulässiger Schnittstellenoperationen.

5.5 Missbrauchs- & Angriffsschutz

5.5.1 Implementierung von Schutzmechanismen gegen automatisierte Angriffe.

5.5.2 Begrenzung ressourcenintensiver oder missbräuchlicher Aktionen.

5.5.3 Erkennung und Protokollierung auffälliger Nutzungsmuster.

5.6 Protokollierung & Sicherheitsüberwachung

5.6.1 Zentrale Erfassung sicherheitsrelevanter Systemereignisse.

5.6.2 Schutz der Protokolldaten vor Manipulation oder unbefugtem Zugriff.

5.6.3 Bereitstellung der Protokolle zur Analyse und Sicherheitsüberwachung.

3 Methoden und Verfahren

4 Theoretische und Technische Grundlagen

5 Bearbeitung der strukturierten Aufgabenstellung

Dieses Kapitel beschreibt die konkrete Umsetzung der in Kapitel 2 definierten Anforderungen. Die Gliederung orientiert sich eins zu eins an der strukturierten Aufgabenstellung, um eine eindeutige Nachvollziehbarkeit zwischen Anforderung und Implementierung sicherzustellen. Für jedes Themengebiet werden die konzeptionellen Entscheidungen, die technische Realisierung sowie die gestalterische Umsetzung erläutert. Ziel ist es, transparent darzustellen, wie die definierten Anforderungen in ein funktionsfähiges System überführt wurden.

1 Kernfunktionen

1.1 Portfoliomanagement

1.1.1 Implementierung einer Funktion zur Erstellung, Bearbeitung und Löschung individueller Benutzerportfolios. **Erfüllungskriterien:**

- **EK-1.1.1.1.1**: Ein authentifizierter Benutzer kann ein neues Portfolio erstellen, das eindeutig seinem Benutzerkonto zugeordnet wird.
- **EK-1.1.1.1.2**: Ein authentifizierter Benutzer kann ausschließlich eigene Portfolios bearbeiten; Änderungen werden persistent gespeichert und sind nach einem erneuten Abruf konsistent sichtbar.
- **EK-1.1.1.1.3**: Ein authentifizierter Benutzer kann ausschließlich eigene Portfolios löschen; der Löschvorgang entfernt das Portfolio dauerhaft oder markiert es nachvollziehbar als gelöscht (Soft-Delete) und verhindert den weiteren Zugriff.

1.1.2 Entwicklung einer Ansicht zur Anzeige aller im Portfolio enthaltenen Positionen einschließlich ihrer relativen Gewichtungen.

Erfüllungskriterien:

- **EK-1.1.2.1**: Die Ansicht listet alle einem ausgewählten Portfolio zugeordneten Positionen vollständig und eindeutig identifizierbar (z. B. Name/ISIN/Ticker) auf.
- **EK-1.1.2.2**: Für jede Position wird die relative Gewichtung am Gesamtportfolio als Prozentwert korrekt berechnet und angezeigt; die Summe aller Gewichtungen beträgt (unter Berücksichtigung von Rundung) 100 %.
- **EK-1.1.2.3**: Die angezeigten Positionen und Gewichtungen entsprechen stets dem aktuellen persistent gespeicherten Stand des Portfolios (keine veralteten oder inkonsistenten Werte nach Änderungen).

1.1.3 Umsetzung einer Darstellung zur Visualisierung historischer Performance- und Wertentwicklungen von Portfolios.

Erfüllungskriterien:

- **EK-1.1.3.1**: Für ein ausgewähltes Portfolio kann die historische Performance/Wertentwicklung für einen definierten Zeitraum (z. B. 1M/3M/1J/Max) geladen und als Zeitreihe dargestellt werden.
- **EK-1.1.3.2**: Die Darstellung basiert auf konsistenten, nachvollziehbaren Berechnungsgrundlagen (z. B. Stichtagswerte, Ein-/Auszahlungen berücksichtigt) und liefert bei identischen Eingabedaten reproduzierbar dieselben Ergebnisse.
- **EK-1.1.3.3**: Interaktionen in der Visualisierung (z. B. Hover/Tooltip, Zoom/Zeitraumauswahl) zeigen zu jedem Zeitpunkt den korrekten Wert/Performance-Kennwert an und bleiben auch bei großen Datenmengen performant nutzbar.

1.2 Marktdaten

1.2.1 Anbindung externer Datenquellen zum Abruf aktueller und historischer Kurs- und Zeitreihendaten.

Erfüllungskriterien:

- **EK-1.2.1.1**: Für eine definierte Menge an Finanzinstrumenten können aktuelle Kurse sowie historische Zeitreihendaten über eine externe Datenquelle automatisiert abgerufen und in einem einheitlichen internen Datenformat gespeichert/verarbeitet werden.
- **EK-1.2.1.2**: Fehlerfälle der Datenquelle (z. B. Timeout, Rate-Limit, ungültige Symbole, API-Fehler) werden robust behandelt: der Abruf liefert verständliche Fehlermeldungen, bricht nicht unkontrolliert ab und verhindert inkonsistente Datenstände.
- **EK-1.2.1.3**: Abgerufene Daten werden nachvollziehbar zeitlich referenziert (Timestamp/Intervall), sodass historische Daten reproduzierbar abrufbar sind und Mehrfachabrufe keine Duplikate oder widersprüchlichen Werte erzeugen.

1.2.2 Implementierung einer Normalisierung und Zwischenspeicherung der abgerufenen Marktdaten.

Erfüllungskriterien:

- **EK-1.2.2.1**: Abgerufene Marktdaten werden unabhängig von der Quelle in ein konsistentes Zielschema normalisiert (z. B. Instrument-ID, Timestamp, Open/High/Low/Close, Volume, Währung) und validiert (Pflichtfelder, Datentypen, Wertebereiche).
- **EK-1.2.2.2**: Die Zwischenspeicherung (Cache) reduziert externe Abrufe messbar: identische Anfragen innerhalb einer definierten TTL bzw. Aktualisierungslogik werden aus dem Cache bedient, ohne die Datenquelle erneut aufzurufen.
- **EK-1.2.2.3**: Cache-Invalidierung und Aktualisierung sind deterministisch und konsistent: veraltete Daten werden erkannt und ersetzt, Parallelzugriffe erzeugen keine Race-Conditions, und es entstehen keine Duplikate oder widersprüchlichen Zeitreihenstände.

1.2.3 Realisierung einer automatisierten Aktualisierung der Marktdaten in definierten Intervallen.

Erfüllungskriterien:

- **EK-1.2.3.1**: Ein Scheduler führt die Aktualisierung der Marktdaten in konfigurierbaren Intervallen (z. B. alle 15 Minuten, täglich) automatisch aus, ohne manuelle Benutzerinteraktion.
- **EK-1.2.3.2**: Jede Ausführung protokolliert nachvollziehbar Start/Ende, Anzahl aktualisierter Instrumente, Fehlerfälle sowie die Ursache (z. B. Rate-Limit, Netzwerkfehler) und ermöglicht eine einfache Nachverfolgung im Betrieb.
- **EK-1.2.3.3**: Die Aktualisierung ist idempotent und ausfallsicher: bei Wiederholungen oder Teilfehlern entstehen keine doppelten Datensätze, der Prozess kann fortgesetzt/neu gestartet werden, und Datenkonsistenz bleibt gewährleistet.

1.3 Nachrichten & Sentiment

1.3.1 Integration externer Nachrichtenquellen zur Anzeige relevanter Informationen zu Finanzinstrumenten und Märkten.

Erfüllungskriterien:

- **EK-1.3.1.1**: Zu einem ausgewählten Finanzinstrument bzw. Marktsegment können passende Nachrichten automatisiert aus mindestens einer externen Quelle abgerufen und in der Anwendung angezeigt werden (inkl. Titel, Quelle, Veröffentlichungsdatum, Link).
- **EK-1.3.1.2**: Die Zuordnung der Nachrichten erfolgt nachvollziehbar (z. B. über Ticker/ISIN/Keywords) und filtert irrelevante Treffer, sodass die angezeigten Inhalte thematisch überwiegend zum Instrument/Markt passen.
- **EK-1.3.1.3**: Die Integration berücksichtigt technische und rechtliche Rahmenbedingungen der Quelle (z. B. Rate-Limits, Caching, Nutzungsbedingungen): Abruf-Fehler werden robust behandelt und die Anzeige bleibt auch bei Quellenausfall funktionsfähig (Fallback/Fehlermeldung).

1.3.2 Aggregation und Bereitstellung von Sentiment-Bewertungen aus externen Datenquellen.

Erfüllungskriterien:

- **EK-1.3.2.1**: Sentiment-Daten (z. B. positiv/neutral/negativ oder Score) werden aus mindestens einer externen Quelle für definierte Finanzinstrumente/Marktsegmente abgerufen, normalisiert und in der Anwendung bereitgestellt.
- **EK-1.3.2.2**: Bei mehreren Quellen werden Sentiment-Bewertungen aggregiert (z. B. gewichteter Mittelwert, Mehrheitsentscheidung) und die Aggregationslogik ist dokumentiert sowie reproduzierbar für identische Eingabedaten.
- **EK-1.3.2.3**: Die Bereitstellung enthält Transparenzinformationen (z. B. Quelle(n), Timestamp, Datenabdeckung/Anzahl Beiträge) und behandelt fehlende/inkonsistente Sentiment-Daten robust (Fallback, Kennzeichnung „nicht verfügbar“).

1.3.3 Implementierung von Filtermechanismen zur themen-, markt- und assetbezogenen Eingrenzung der Inhalte.

Erfüllungskriterien:

- **EK-1.3.3.1**: Inhalte (z. B. Nachrichten, Sentiment) können nach Thema (Keywords/Kategorien) gefiltert werden; die Ergebnisliste enthält ausschließlich Einträge, die die gewählten Themenkriterien erfüllen.
- **EK-1.3.3.2**: Inhalte können nach Marktsegment (z. B. Region, Index, Branche) und nach Asset/Finanzinstrument (z. B. Ticker/ISIN) gefiltert werden; kombinierte Filter (UND-Verknüpfung) liefern konsistente, nachvollziehbare Ergebnisse.
- **EK-1.3.3.3**: Filterzustände sind in der UI klar ersichtlich, können zurückgesetzt werden und wirken ohne Dateninkonsistenzen (keine „Geister“-Einträge, korrekte Paginierung/Sortierung nach Filterwechsel).

1.4 Fundamentalanalyse

1.4.1 Berechnung fundamentaler Kennzahlen auf Basis interner und externer Datenquellen.

Erfüllungskriterien:

- **EK-1.4.1.1**: Fundamentale Kennzahlen (z. B. KGV, KBV, Umsatzwachstum, EBITDA-Marge) werden auf Basis definierter Formeln aus internen und externen Datenquellen korrekt berechnet; die zugrunde liegenden Berechnungsregeln sind dokumentiert und reproduzierbar.
- **EK-1.4.1.2**: Die Berechnung berücksichtigt unterschiedliche Berichtszeiträume und Währungen (inkl. Umrechnung und Periodenabgleich) und liefert konsistente Ergebnisse bei identischen Eingabedaten.
- **EK-1.4.1.3**: Fehlende, veraltete oder inkonsistente Eingangsdaten werden erkannt und transparent behandelt (z. B. Kennzeichnung „nicht berechenbar“, Plausibilitätsprüfung), ohne fehlerhafte Kennzahlen auszugeben.

1.4.2 Umsetzung historischer Vergleiche fundamentaler Kennzahlen über definierte Zeiträume.

Erfüllungskriterien:

- **EK-1.4.2.1**: Für definierte fundamentale Kennzahlen können Werte über wählbare Zeiträume (z. B. 3/5/10 Jahre, Quartale) historisch abgerufen und in strukturierter Form (Tabelle und/oder Zeitreihe) dargestellt werden.
- **EK-1.4.2.2**: Veränderungen (absolute und prozentuale Abweichungen) zwischen Zeitpunkten werden korrekt berechnet und nachvollziehbar ausgewiesen; identische Eingangsdaten führen reproduzierbar zu denselben Vergleichsergebnissen.
- **EK-1.4.2.3**: Unterschiedliche Berichtsstandards, Währungen oder Periodenverschiebungen werden konsistent harmonisiert; fehlende Werte werden transparent gekennzeichnet und verfälschen die Vergleichsberechnung nicht.

1.4.3 Darstellung der Analyseergebnisse in strukturierter Form mittels Tabellen und Diagrammen.

Erfüllungskriterien:

- **EK-1.4.3.1**: Analyseergebnisse werden in tabellarischer Form vollständig, korrekt formatiert (z. B. Einheiten, Prozentangaben, Rundung) und eindeutig beschriftet dargestellt; Sortierung und Paginierung funktionieren konsistent.
- **EK-1.4.3.2**: Relevante Kennzahlen und Zeitreihen werden zusätzlich in geeigneten Diagrammtypen (z. B. Linien-, Balken- oder Säulendiagramm) visualisiert; die grafische Darstellung entspricht den zugrunde liegenden Datenwerten ohne Abweichung.
- **EK-1.4.3.3**: Tabellen und Diagramme reagieren konsistent auf Filter-, Zeitraum- oder Portfolioänderungen; Aktualisierungen erfolgen ohne Inkonsistenzen, Darstellungsfehler oder veraltete Datenstände.

1.5 Alerts & Benachrichtigungen

1.5.1 Implementierung einer Funktion zur Definition benutzerindividueller Alert-Regeln.

Erfüllungskriterien:

- **EK-1.5.1.1**: Ein authentifizierter Benutzer kann Alert-Regeln mit definierten Parametern anlegen (z. B. Instrument/Portfolio, Kennzahl, Schwellwert, Vergleichsoperator, Zeitraum, Benachrichtigungskanal) und diese werden persistent gespeichert.
- **EK-1.5.1.2**: Ein authentifizierter Benutzer kann ausschließlich eigene Alert-Regeln anzeigen, bearbeiten und löschen; unautorisierte Zugriffe auf Regeln anderer Benutzer werden serverseitig verhindert.
- **EK-1.5.1.3**: Jede Regel wird vor dem Speichern validiert (z. B. Pflichtfelder, Wertebereiche, zulässige Operatoren); ungültige Regeln werden mit verständlichen Fehlermeldungen abgewiesen, ohne inkonsistente Konfigurationen zu erzeugen.

1.5.2 Entwicklung einer Verwaltungsoberfläche zur Übersicht und Pflege bestehender Alerts.

Erfüllungskriterien:

- **EK-1.5.2.1**: Alle vom Benutzer definierten Alert-Regeln werden in einer strukturierten Übersicht angezeigt (inkl. Instrument/Portfolio, Bedingung, Status, Benachrichtigungskanal).
- **EK-1.5.2.2**: Die Oberfläche ermöglicht das Aktivieren/Deaktivieren einzelner Alerts ohne Datenverlust; Statusänderungen werden unmittelbar persistent gespeichert.
- **EK-1.5.2.3**: Änderungen oder Löschungen von Alerts wirken sich konsistent auf die zugrunde liegende Prüf-Logik aus und führen zu keiner veralteten oder weiterhin aktiven Regel im System.

1.5.3 Umsetzung eines Mechanismus zur Auslösung systeminterner Benachrichtigungen bei Erreichen definierter Bedingungen.

Erfüllungskriterien:

- **EK-1.5.3.1**: Das System prüft definierte Alert-Bedingungen automatisiert und löst bei Erfüllung eine Benachrichtigung aus.
- **EK-1.5.3.2**: Benachrichtigungen enthalten alle relevanten Kontextinformationen (Instrument/Portfolio, Kennzahl, Schwellwert, aktueller Wert, Zeitpunkt).
- **EK-1.5.3.3**: Mehrfachauslösungen derselben Bedingung werden kontrolliert behandelt (z. B. Cooldown-Logik oder Statusänderung), sodass keine unkontrollierten Benachrichtigungsfluten entstehen.

1.6 Technische Analyse

1.6.1 Implementierung der Berechnung gängiger technischer Indikatoren.

Erfüllungskriterien:

- **EK-1.6.1.1**: Technische Indikatoren (z. B. SMA, EMA, RSI, MACD) werden auf Basis historischer Kursdaten korrekt und reproduzierbar berechnet.
- **EK-1.6.1.2**: Parameter (z. B. Periodenlänge) sind konfigurierbar; identische Eingangsdaten und Parameter liefern identische Ergebnisse.
- **EK-1.6.1.3**: Unzureichende oder fehlerhafte Eingangsdaten werden erkannt und führen nicht zu fehlerhaften Indikatorwerten (z. B. durch Kennzeichnung „nicht berechenbar“).

1.6.2 Visualisierung der Ergebnisse technischer Analysen in geeigneten Chart-Darstellungen.

Erfüllungskriterien:

- **EK-1.6.2.1**: Indikatoren werden korrekt über oder unter dem Kurschart dargestellt (z. B. RSI im separaten Panel); die Darstellung entspricht exakt den berechneten Werten.
- **EK-1.6.2.2**: Skalen und Achsen sind konsistent und verzerren keine Indikatorwerte; Wechsel von Zeitraum/Intervall aktualisiert die Darstellung deterministisch.
- **EK-1.6.2.3**: Interaktive Elemente (Tooltip, Zoom, Zeitraumwechsel) aktualisieren alle Indikatoren synchron und ohne Inkonsistenzen.

1.6.3 Ermöglichung der kombinierten Nutzung mehrerer technischer Indikatoren innerhalb einer Analyse.

Erfüllungskriterien:

- **EK-1.6.3.1**: Mehrere Indikatoren können gleichzeitig aktiviert und dargestellt werden; Auswahl und Reihenfolge sind nachvollziehbar.
- **EK-1.6.3.2**: Überlagerungen oder parallele Darstellungen bleiben visuell unterscheidbar (z. B. Legende, Linienzuordnung, Panel-Trennung).
- **EK-1.6.3.3**: Die Performance bleibt auch bei mehreren aktiven Indikatoren stabil und reaktionsfähig (z. B. keine UI-Blockaden bei Interaktionen).

1.7 Quantitative Analyse & Screening

1.7.1 Entwicklung einer Funktion zur Definition regelbasierter Screening-Kriterien.

Erfüllungskriterien:

- **EK-1.7.1.1**: Benutzer können Screening-Regeln mit Kennzahlen, Vergleichsoperatoren und Schwellenwerten definieren; die Regeln sind eindeutig interpretierbar.
- **EK-1.7.1.2**: Regeln werden vor Speicherung validiert (Pflichtfelder, Datentypen, Wertebereiche) und persistent gespeichert.
- **EK-1.7.1.3**: Die Regeldefinition verhindert widersprüchliche oder syntaktisch ungültige Konfigurationen und liefert verständliche Fehlermeldungen.

1.7.2 Umsetzung quantitativer Analyseverfahren auf Basis definierter Regeln.

Erfüllungskriterien:

- **EK-1.7.2.1**: Screening-Regeln werden automatisiert auf eine definierte Menge von Finanzinstrumenten angewendet; die Ausführung ist wiederholbar und deterministisch.
- **EK-1.7.2.2**: Ergebnisse sind reproduzierbar bei identischen Datenständen (inkl. Zeitstempel der Datenbasis) und werden nachvollziehbar protokolliert.
- **EK-1.7.2.3**: Teilfehler (z. B. fehlende Daten einzelner Instrumente) beeinträchtigen nicht die Gesamtauswertung; betroffene Ergebnisse werden transparent gekennzeichnet.

1.7.3 Implementierung eines Vergleichs und einer Auswertung der generierten Analyseergebnisse.

Erfüllungskriterien:

- **EK-1.7.3.1**: Ergebnisse können sortiert, gefiltert und nach definierten Kennzahlen verglichen werden; die Darstellung bleibt konsistent bei Filterwechseln.
- **EK-1.7.3.2**: Rangfolgen oder Scoring-Modelle sind nachvollziehbar dokumentiert; identische Eingabedaten führen zu identischen Rankings.
- **EK-1.7.3.3**: Änderungen an Regeln oder Datenständen führen zu konsistenter Neuberechnung aller betroffenen Ergebnisse ohne veraltete Zwischenergebnisse.

1.8 Makro- & Marktumfeld

Beschreibung:
Das System stellt makroökonomische Kennzahlen sowie aggregierte Marktindikatoren zur Verfügung, um Einzelanalysen in einen gesamtwirtschaftlichen und kapitalmarktbezogenen Kontext einzuordnen. Relevante Zeitreihen werden automatisiert aus externen Datenquellen abgerufen, validiert, zeitlich referenziert und konsistent bereitgestellt. Ergänzend werden Marktüberblicke (z. B. Indizes, Branchen, Regionen, Volatilität) strukturiert dargestellt und aufbereitet. Fehlende oder fehlerhafte Daten werden transparent gekennzeichnet; Aktualisierungen erfolgen konsistent und nachvollziehbar.

Relevante Security Requirements:

- **SR-6** – Absicherung externer Schnittstellen *(Tampering)*
- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*
- **SR-10** – Sicherstellung der Verfügbarkeit *(Denial of Service)*

1.8.1 Integration makroökonomischer Kennzahlen aus externen Datenquellen.

Erfüllungskriterien:

- **EK-1.8.1.1**: Makroökonomische Kennzahlen können aus mindestens einer externen Quelle automatisiert abgerufen und in der Anwendung bereitgestellt werden.
- **EK-1.8.1.2**: Daten werden zeitlich referenziert (Periode, Timestamp) und in einem einheitlichen Schema gespeichert; Mehrfachabrufe erzeugen keine Duplikate oder widersprüchliche Werte.
- **EK-1.8.1.3**: Fehlerfälle (z. B. Quellenausfall, ungültige Serien, Rate-Limits) werden robust behandelt; fehlende Werte werden transparent gekennzeichnet.

muss das hier hin oder in Objektivirter Ergebnissteil? fehlt da was? darf das so aufgebaut sein?

Status: Vollständig erfüllt.

Nachweis der Erfüllung:

- **EK-1.8.1.1**
  Das Kriterium ist erfüllt. Makroökonomische Kennzahlen werden automatisiert über eine externe REST-API abgerufen. Der Abruf erfolgt periodisch über einen implementierten Hintergrundprozess (Scheduler). Die Daten werden nach erfolgreicher Validierung persistiert und innerhalb der Anwendung zur weiteren Verarbeitung und Visualisierung bereitgestellt.

- **EK-1.8.1.2**
  Das Kriterium ist erfüllt. Sämtliche importierten Datensätze enthalten eine eindeutige zeitliche Referenz (Periode bzw. Timestamp). Die Speicherung erfolgt in einem einheitlichen, normalisierten Schema. Zur Vermeidung von Duplikaten wurde ein eindeutiger Datenbank-Constraint (z. B. Kombination aus `indicator_id` und `period`) implementiert. Mehrfachabrufe identischer Zeiträume führen durch eine Upsert-Strategie nicht zu widersprüchlichen Einträgen.

- **EK-1.8.1.3**
  Das Kriterium ist erfüllt. Fehlerfälle wie API-Nichtverfügbarkeit, ungültige Serienkennungen oder Rate-Limit-Überschreitungen werden durch strukturiertes Exception-Handling abgefangen. Fehler werden protokolliert und bei fehlenden Werten erfolgt eine transparente Kennzeichnung in der Benutzeroberfläche. Zusätzlich wurde ein Retry-Mechanismus mit Backoff-Strategie implementiert.

BSP(Python)

```python
# test_macro_service.py

import pytest
from macro_service import fetch_macro_data

def test_fetch_macro_data_returns_dict():
    data = fetch_macro_data("inflation")
    assert isinstance(data, dict)

def test_macro_data_contains_required_fields():
    data = fetch_macro_data("inflation")

    assert "value" in data
    assert "timestamp" in data
    assert data["value"] is not None

def test_invalid_series_raises_error():
    with pytest.raises(ValueError):
        fetch_macro_data("invalid_series")
```

Listing 1: Beispiel(Python)

1.8.2 Bereitstellung übersichtlicher Marktüberblicke zur Kontextualisierung einzelner Analysen.

Erfüllungskriterien:

- **EK-1.8.2.1**: Marktüberblicke fassen relevante Indikatoren/Segmente (z. B. Indizes, Branchen, Regionen, Volatilität) in einer konsistenten Übersicht zusammen.
- **EK-1.8.2.2**: Die Darstellung ermöglicht einen schnellen Vergleich (z. B. Tages-/Wochen-/Monatsänderung) und ist nachvollziehbar (Quellenangabe, Zeitbezug).
- **EK-1.8.2.3**: Aktualisierungen und Filter wirken ohne Inkonsistenzen; es werden keine veralteten Datenstände angezeigt.

1.8.3 Umsetzung zeitlicher Vergleiche makroökonomischer und marktbezogener Daten.

Erfüllungskriterien:

- **EK-1.8.3.1**: Zeitreihen können für definierte Zeiträume geladen und verglichen werden (z. B. YoY/MoM/Quartalsvergleich), inkl. korrekter Periodenabgrenzung.
- **EK-1.8.3.2**: Abweichungen werden korrekt als absolute und prozentuale Differenzen berechnet; identische Eingabedaten liefern reproduzierbare Ergebnisse.
- **EK-1.8.3.3**: Fehlende Perioden/Werte werden transparent gekennzeichnet und verfälschen die Vergleichslogik nicht (z. B. keine Division durch Null, keine implizite Imputation ohne Kennzeichnung).

2 User Interface & Interaction Design

2.1 Kernflows

2.1.1 Gestaltung konsistenter Navigationspfade zwischen den zentralen Kernfunktionen der Plattform.

Erfüllungskriterien:

- **EK-2.1.1.1**: Für alle Kernfunktionen existieren eindeutige, konsistente Navigationspfade (z. B. Portfolio → Positionen → Detail/Analyse) ohne Sackgassen.
- **EK-2.1.1.2**: Navigationselemente (Menü, Breadcrumbs, Buttons) sind einheitlich benannt und führen deterministisch zum erwarteten Ziel.
- **EK-2.1.1.3**: Der aktuelle Kontext (z. B. ausgewähltes Portfolio/Instrument) bleibt beim Wechsel zwischen Kernfunktionen nachvollziehbar erhalten oder wird bewusst zurückgesetzt und angezeigt.

2.1.2 Definition einheitlicher Seitenabfolgen innerhalb der Kernnutzungsflüsse.

Erfüllungskriterien:

- **EK-2.1.2.1**: Für zentrale Use-Cases sind standardisierte Seitenabfolgen definiert und umgesetzt (z. B. Erstellen → Konfigurieren → Bestätigen).
- **EK-2.1.2.2**: Wiederkehrende Seitenmuster (z. B. Listen-/Detailansicht) folgen konsistenten Layout- und Interaktionsregeln.
- **EK-2.1.2.3**: Übergänge zwischen Seiten sind nachvollziehbar und vermeiden unerwartete Zustandswechsel (z. B. Verlust von Filter-/Zeitraumzustand ohne Hinweis).

2.1.3 Reduktion unnötiger Interaktionsschritte zur Optimierung der Nutzerführung.

Erfüllungskriterien:

- **EK-2.1.3.1**: Kernaufgaben können in minimaler Klick-/Schrittanzahl ausgeführt werden (z. B. Portfolioauswahl → Analyse ohne redundante Zwischenseiten).
- **EK-2.1.3.2**: Wiederkehrende Eingaben werden durch Defaults, Autovervollständigung oder Speicherung von Präferenzen reduziert, ohne die Kontrolle des Nutzers einzuschränken.
- **EK-2.1.3.3**: UX-Entscheidungen werden durch konsistente Feedback-Mechanismen unterstützt (z. B. Ladezustand, Erfolgsmeldung, Undo/Bestätigung wo erforderlich).

2.2 Informationsarchitektur

2.2.1 Strukturierung der Inhalte in klar abgegrenzte und logisch aufgebaute Bereiche.

Erfüllungskriterien:

- **EK-2.2.1.1**: Inhalte sind in logisch benannte Bereiche gegliedert (z. B. Portfolio, Analyse, Nachrichten, Einstellungen) und sind für Nutzer ohne zusätzliche Erklärung auffindbar.
- **EK-2.2.1.2**: Innerhalb eines Bereichs sind Funktionen in konsistente Sub-Strukturen organisiert (z. B. Listen → Detail → Aktionen).
- **EK-2.2.1.3**: Die Informationshierarchie ist visuell eindeutig (Überschriften, Abstände, Gruppierungen) und verhindert Überladung einzelner Screens.

2.2.2 Implementierung einer eindeutigen und konsistenten Navigationsstruktur.

Erfüllungskriterien:

- **EK-2.2.2.1**: Hauptnavigation und sekundäre Navigation (Tabs/Seitenleisten) sind konsistent und decken alle Kernbereiche ab.
- **EK-2.2.2.2**: Navigationszustände (aktiv/inaktiv, hover/focus) sind eindeutig und barrierearm umgesetzt.
- **EK-2.2.2.3**: Navigationsentscheidungen sind rückwärts-kompatibel zur erwarteten Nutzerführung (Back-Button, Breadcrumbs, Deep-Links ohne Inkonsistenzen).

2.2.3 Vermeidung redundanter oder widersprüchlicher Darstellungen innerhalb der Benutzeroberfläche.

Erfüllungskriterien:

- **EK-2.2.3.1**: Gleichartige Informationen werden nicht mehrfach in abweichender Bedeutung dargestellt (z. B. Performance-Kennzahl stets identisch berechnet und benannt).
- **EK-2.2.3.2**: Darstellung und Terminologie sind über alle Screens konsistent (z. B. „Position“ vs. „Asset“ wird nicht wechselnd verwendet).
- **EK-2.2.3.3**: Inkonsistenzen durch Caching/State werden vermieden; UI reflektiert nach Aktionen stets den persistierten Systemzustand.

2.3 Responsiveness

2.3.1 Sicherstellung der Nutzbarkeit der Plattform auf Desktop-, Tablet- und mobilen Endgeräten.

Erfüllungskriterien:

- **EK-2.3.1.1**: Alle Kernfunktionen sind auf Desktop, Tablet und Mobile funktional nutzbar (keine funktionslosen Views oder abgeschnittene Interaktionen).
- **EK-2.3.1.2**: Touch- und Mausinteraktionen sind berücksichtigt (z. B. ausreichend große Targets, Scrollverhalten, Gesten/Pinch-Alternativen).
- **EK-2.3.1.3**: Kritische Inhalte (Charts, Tabellen, Formulare) bleiben auch auf kleinen Screens verständlich und bedienbar.

2.3.2 Anpassung von Layouts und Interaktionselementen an unterschiedliche Bildschirmgrößen.

Erfüllungskriterien:

- **EK-2.3.2.1**: Layouts reagieren responsiv (Breakpoints, Fluid-Grids) und nutzen Screenfläche effizient, ohne Informationsverlust.
- **EK-2.3.2.2**: Interaktionselemente (Buttons, Inputs, Filter) passen sich in Größe/Anordnung an und bleiben erreichbar.
- **EK-2.3.2.3**: Tabellen/Charts bieten responsive Strategien (z. B. horizontales Scrollen, Spaltenpriorisierung, Zusammenfassung), ohne falsche Dateninterpretation zu erzeugen.

2.3.3 Überprüfung der vollständigen Sicht- und Bedienbarkeit aller Inhalte auf verschiedenen Endgeräten.

Erfüllungskriterien:

- **EK-2.3.3.1**: Für definierte Referenzgeräte/Viewport-Größen existiert eine nachvollziehbare Testabdeckung (manuell oder automatisiert).
- **EK-2.3.3.2**: Keine UI-Elemente sind verdeckt oder nicht erreichbar (z. B. modale Dialoge, Dropdowns, Toasts).
- **EK-2.3.3.3**: Medien-/Darstellungsfehler (z. B. Overflow, gebrochene Zeilen, abgeschnittene Achsen) sind behoben oder durch Layoutregeln verhindert.

2.4 Charting

2.4.1 Implementierung interaktiver Charts zur grafischen Analyse von Daten.

Erfüllungskriterien:

- **EK-2.4.1.1**: Charts unterstützen Interaktionen (z. B. Tooltip, Zoom, Zeitraumfilter) und liefern korrekte Werte zu jedem Interaktionspunkt.
- **EK-2.4.1.2**: Interaktionen wirken deterministisch und ohne UI-Fehler (z. B. keine Sprünge, keine falschen Tooltips, keine „hängenden“ Zustände).
- **EK-2.4.1.3**: Charts bleiben auch bei größeren Datenmengen performant (z. B. ohne spürbare Ruckler bei Pan/Zoom).

2.4.2 Sicherstellung einer einheitlichen Skalierung und konsistenten Darstellung der Visualisierungen.

Erfüllungskriterien:

- **EK-2.4.2.1**: Skalierung/Achsenlogik ist innerhalb vergleichbarer Charts konsistent (z. B. gleiche Einheit, gleiche Prozentbasis, gleiche Nullpunktlogik).
- **EK-2.4.2.2**: Zeitachsen sind korrekt (Zeitzone, Handelstage, Intervalle) und vermeiden falsche Verdichtungen oder Lücken ohne Kennzeichnung.
- **EK-2.4.2.3**: Der Wechsel von Zeitraum/Instrument führt zu konsistenter Neuberechnung und Neurendering ohne veraltete Datenstände.

2.4.3 Gewährleistung einer korrekten Abbildung der zugrunde liegenden Daten in allen Charts.

Erfüllungskriterien:

- **EK-2.4.3.1**: Chartwerte entsprechen exakt den zugrunde liegenden Datenpunkten (keine stillschweigende Glättung/Interpolation ohne Kennzeichnung).
- **EK-2.4.3.2**: Rundungs- und Formatierungsregeln sind konsistent (z. B. Dezimalstellen, Währungen, Prozentwerte) und verzerren keine Interpretation.
- **EK-2.4.3.3**: Bei Datenlücken oder unvollständigen Reihen wird dies transparent dargestellt (z. B. Lücken, Marker, Hinweistext) statt falsche Kontinuität zu suggerieren.

2.5 Benutzerfreundlichkeit & Performance

2.5.1 Optimierung der Reaktionszeiten der Benutzeroberfläche.

Erfüllungskriterien:

- **EK-2.5.1.1**: Interaktionen (Navigation, Filter, Auswahl) reagieren innerhalb definierter Zielwerte ohne spürbare Verzögerung.
- **EK-2.5.1.2**: Ladezustände werden klar angezeigt (Skeleton/Spinner) und verhindern Mehrfachauslösungen (z. B. Double-Click).
- **EK-2.5.1.3**: Rendering und State-Updates vermeiden unnötige Re-Renders; Performance-Probleme sind mess- und reproduzierbar identifiziert.

2.5.2 Reduktion unnötiger Lade- und Wartezeiten.

Erfüllungskriterien:

- **EK-2.5.2.1**: Datenabrufe sind effizient (Caching/Pagination/Incremental Loading) und vermeiden überflüssige Netzwerkanfragen.
- **EK-2.5.2.2**: Priorisierung kritischer Inhalte (Above-the-fold) ist umgesetzt; sekundäre Inhalte werden nachgeladen, ohne Kernflows zu blockieren.
- **EK-2.5.2.3**: Wiederkehrende Operationen nutzen lokale Zustände/Cache, ohne Inkonsistenzen zum persistierten Stand zu erzeugen.

2.5.3 Sicherstellung einer stabilen und fehlerfreien Darstellung auch bei hoher Systemlast.

Erfüllungskriterien:

- **EK-2.5.3.1**: UI bleibt bedienbar bei hoher Datenlast (z. B. große Portfolios, lange Zeitreihen) ohne Abstürze oder Rendering-Fehler.
- **EK-2.5.3.2**: Fehlerfälle (Timeouts, Rate-Limits) führen zu kontrollierten Fehlermeldungen und degradierten, aber nutzbaren Zuständen.
- **EK-2.5.3.3**: Wiederholtes Laden/Filtern führt nicht zu Memory-Leaks oder schleichender Degradation (z. B. durch nicht freigegebene Ressourcen).

2.6 Barrierefreiheit & Lesbarkeit

2.6.1 Umsetzung einer kontrastreichen Darstellung aller Inhalte.

Erfüllungskriterien:

- **EK-2.6.1.1**: Text- und UI-Kontraste sind ausreichend, sodass Inhalte unabhängig vom Theme (hell/dunkel) lesbar bleiben.
- **EK-2.6.1.2**: Kontrastkritische Informationen werden nicht ausschließlich über Farbe codiert (z. B. zusätzlich Icons/Labels).
- **EK-2.6.1.3**: Charts berücksichtigen Lesbarkeit (Achsen, Legenden, Hover-Infos) und bleiben auch bei geringer Sehschärfe interpretierbar.

2.6.2 Ermöglichung skalierbarer Schriftgrößen ohne Funktionsverlust.

Erfüllungskriterien:

- **EK-2.6.2.1**: UI bleibt bei vergrößerter Schrift (z. B. Browser-Zoom, OS-Skalierung) nutzbar; keine Überlappungen verhindern Bedienung.
- **EK-2.6.2.2**: Typografie nutzt relative Einheiten/Responsive Regeln; Zeilenumbrüche sind kontrolliert.
- **EK-2.6.2.3**: Kritische Komponenten (Tabellen/Forms/Charts) bieten Alternativen (Scroll, Reflow, Collapse), ohne Informationen zu verlieren.

2.6.3 Verwendung verständlicher und eindeutiger Beschriftungen in der Benutzeroberfläche.

Erfüllungskriterien:

- **EK-2.6.3.1**: Labels, Buttons und Fehlermeldungen sind eindeutig, kurz und vermeiden Mehrdeutigkeiten.
- **EK-2.6.3.2**: Fachbegriffe sind konsistent; falls notwendig werden sie durch Tooltips/Helptext erklärt.
- **EK-2.6.3.3**: Übersetzungen (I18n) ändern die Bedeutung nicht und vermeiden abgeschnittene Texte durch Layoutregeln.

2.7 Guided UX

2.7.1 Implementierung von Tooltips zur kontextbezogenen Unterstützung der Nutzer.

Erfüllungskriterien:

- **EK-2.7.1.1**: Tooltips sind an relevanten UI-Elementen verfügbar (z. B. Kennzahlen, Filter, Charts) und liefern kontextgenaue Informationen.
- **EK-2.7.1.2**: Tooltips sind barrierearm (Keyboard/Focus erreichbar) und verdecken keine kritischen Inhalte dauerhaft.
- **EK-2.7.1.3**: Tooltip-Inhalte sind konsistent, kurz und fachlich korrekt; sie widersprechen nicht der Systemlogik.

2.7.2 Bereitstellung erklärender Hinweise zu Funktionen und Nutzungspfaden.

Erfüllungskriterien:

- **EK-2.7.2.1**: Für zentrale Funktionen existieren erklärende Hinweise (z. B. leere Zustände, Onboarding, Inline-Hinweise).
- **EK-2.7.2.2**: Hinweise erscheinen situationsabhängig (z. B. erste Nutzung, fehlende Daten) und stören Kernflows nicht dauerhaft.
- **EK-2.7.2.3**: Nutzer können Hinweise schließen/unterdrücken; der Zustand wird konsistent gespeichert (z. B. „Nicht mehr anzeigen“).

2.7.3 Umsetzung einer schrittweisen Unterstützung bei komplexeren Interaktionen.

Erfüllungskriterien:

- **EK-2.7.3.1**: Komplexe Prozesse (z. B. Alert-Regel, Screening-Regel) werden in nachvollziehbare Schritte zerlegt (Wizard/Stepper).
- **EK-2.7.3.2**: Jeder Schritt validiert Eingaben und gibt verständliches Feedback, bevor der nächste Schritt möglich ist.
- **EK-2.7.3.3**: Abbruch/Zurück-Navigation führt zu konsistentem Zustand (z. B. keine halbfertigen Konfigurationen ohne Kennzeichnung).

2.8 Internationalisierung

2.8.1 Implementierung einer Umschaltfunktion zwischen unterstützten Sprachen.

Erfüllungskriterien:

- **EK-2.8.1.1**: Nutzer können zwischen den unterstützten Sprachen umschalten; die Umschaltung wirkt unmittelbar auf UI-Texte.
- **EK-2.8.1.2**: Die Spracheinstellung wird persistent gespeichert und bei erneutem Login/Reload korrekt wiederhergestellt.
- **EK-2.8.1.3**: Umschaltung führt zu keinem inkonsistenten Zustand (z. B. gemischte Sprachen in UI-Komponenten).

2.8.2 Anzeige lokalisierter Texte und Inhalte entsprechend der Spracheinstellung.

Erfüllungskriterien:

- **EK-2.8.2.1**: Alle UI-Texte sind über ein I18n-System ausgelagert und pro Sprache vollständig vorhanden (keine „Hardcoded Strings“ in Kernbereichen).
- **EK-2.8.2.2**: Formate (Datum/Zeit, Dezimaltrennzeichen, Währung) entsprechen der gewählten Locale bzw. sind konsistent definiert.
- **EK-2.8.2.3**: Fallback-Regeln (z. B. Missing Keys) sind definiert und führen zu kontrollierter Anzeige statt zu UI-Fehlern.

2.8.3 Sicherstellung der konsistenten Funktionalität unabhängig von der gewählten Sprache.

Erfüllungskriterien:

- **EK-2.8.3.1**: Kernfunktionen (Navigation, Formulare, Validierung) funktionieren identisch in allen unterstützten Sprachen.
- **EK-2.8.3.2**: Layout bleibt stabil bei längeren Übersetzungen; kritische Texte werden nicht abgeschnitten oder unlesbar.
- **EK-2.8.3.3**: Sprachumschaltung beeinflusst keine Datenlogik (z. B. keine Änderung von IDs, Filtern oder Berechnungen).

3 Informationsdarstellung & Risikokommunikation

3.1 Darstellung von Marktdaten & Analysen

3.1.1 Implementierung einer konsistenten Visualisierung von Marktdaten und Analyseergebnissen.

Erfüllungskriterien:

- **EK-3.1.1.1**: Marktdaten und Analyseergebnisse werden in konsistenten Komponenten (Tabellen/Charts/Karten) dargestellt; gleiche Daten werden nicht unterschiedlich visualisiert.
- **EK-3.1.1.2**: Einheiten, Rundungen und Währungsdarstellungen sind konsistent und nachvollziehbar (z. B. immer Basiswährung + Kennzeichnung).
- **EK-3.1.1.3**: Darstellungen werden bei Datenupdates deterministisch aktualisiert (keine veralteten Werte durch Cache/UI-State).

3.1.2 Kontextualisierung von Kennzahlen zur Unterstützung einer eindeutigen Interpretation.

Erfüllungskriterien:

- **EK-3.1.2.1**: Kennzahlen enthalten Kontext (z. B. Zeitraum, Berechnungsbasis, Quelle), der direkt in UI oder via Tooltip einsehbar ist.
- **EK-3.1.2.2**: Vergleichsmaßstäbe (z. B. Benchmark, historische Werte) sind klar gekennzeichnet und methodisch konsistent.
- **EK-3.1.2.3**: Potenziell missverständliche Kennzahlen (z. B. Prozent vs. absolute Rendite) sind eindeutig bezeichnet und formatkonform.

3.1.3 Sicherstellung einer einheitlichen Darstellungslogik über alle Analyseansichten hinweg.

Erfüllungskriterien:

- **EK-3.1.3.1**: Gleiche Filter (Zeitraum, Instrument, Portfolio) wirken in allen Analyseansichten nach identischen Regeln.
- **EK-3.1.3.2**: Sortierung, Paginierung und leere Zustände sind konsistent implementiert (z. B. gleiche Defaults, gleiche Texte).
- **EK-3.1.3.3**: Berechnungslogik ist zentralisiert oder konsistent wiederverwendet; divergierende Berechnungen zwischen Screens sind ausgeschlossen.

3.2 Nachrichten- & Sentimentdarstellung

3.2.1 Trennung von Nachrichten, Analysen und Meinungen innerhalb der Darstellung.

Erfüllungskriterien:

- **EK-3.2.1.1**: Nachrichten (Fakten), Sentiment/Analysen und ggf. Nutzermeinungen sind UI-seitig klar getrennt (z. B. Tabs/Badges/Sectioning).
- **EK-3.2.1.2**: Jede Kategorie hat eindeutige Kennzeichnung und konsistente Metadaten (Quelle, Datum, Datenbasis).
- **EK-3.2.1.3**: Mischdarstellungen, die Interpretationsfehler fördern, werden vermieden (z. B. Sentiment nicht als „Nachricht“ dargestellt).

3.2.2 Eindeutige Kennzeichnung externer Inhalte als solche.

Erfüllungskriterien:

- **EK-3.2.2.1**: Externe Inhalte sind sichtbar als extern gekennzeichnet (Quelle/Publisher, Link, Zeitstempel).
- **EK-3.2.2.2**: Die Anwendung gibt keine falsche Urheberschaft vor (z. B. keine Darstellung als „eigene Empfehlung“ ohne Hinweis).
- **EK-3.2.2.3**: Nutzungsbedingungen/Limitierungen (z. B. Datenabdeckung, Rate-Limits) werden transparent gemacht, sofern dies die Interpretation beeinflusst.

3.2.3 Kontextbezogene Präsentation von Nachrichten- und Sentimentinformationen.

Erfüllungskriterien:

- **EK-3.2.3.1**: Inhalte werden kontextualisiert (z. B. Bezug auf Instrument/Portfolio, Zeitraum, Relevanzfilter).
- **EK-3.2.3.2**: Sortierung/Filter (Datum, Relevanz, Thema) funktionieren konsistent und beeinflussen keine Datenintegrität.
- **EK-3.2.3.3**: Bei fehlenden Daten (keine Nachrichten/Sentiment) werden sinnvolle leere Zustände angezeigt (statt leere Listen ohne Erklärung).

3.3 Risikohinweise & Warnmeldungen

3.3.1 Einbindung von Risikohinweisen im Kontext analytischer Auswertungen.

Erfüllungskriterien:

- **EK-3.3.1.1**: Risikohinweise werden in Analysekontexten angezeigt, in denen Interpretationsrisiken bestehen (z. B. Datenlücken, hohe Volatilität, Modellannahmen).
- **EK-3.3.1.2**: Hinweise sind konkret, nicht generisch, und beziehen sich auf den aktuellen Zustand (z. B. „Daten für Zeitraum X unvollständig“).
- **EK-3.3.1.3**: Risikohinweise sind konsistent platziert und nicht irreführend (keine widersprüchliche Einstufung in verschiedenen Screens).

3.3.2 Anzeige von Warnmeldungen bei unvollständigen oder unsicheren Daten.

Erfüllungskriterien:

- **EK-3.3.2.1**: Bei unvollständigen/unsicheren Daten wird sichtbar gewarnt (Banner/Badge), inkl. Ursache und betroffenen Bereichen.
- **EK-3.3.2.2**: Warnmeldungen verhindern falsche Schlussfolgerungen (z. B. Deaktivierung bestimmter Kennzahlen, Kennzeichnung „nicht berechenbar“).
- **EK-3.3.2.3**: Warnmeldungen sind nachvollziehbar und wiederholbar; identische Datenlage erzeugt identische Warnstufe.

3.3.3 Bereitstellung von Hinweisen auf externe Abhängigkeiten und Datenquellen.

Erfüllungskriterien:

- **EK-3.3.3.1**: Für zentrale Datenpunkte sind Quelle und Zeitpunkt der Aktualisierung einsehbar.
- **EK-3.3.3.2**: Bei Ausfällen externer Abhängigkeiten wird dies transparent gemacht, ohne interne Systemdetails offenzulegen.
- **EK-3.3.3.3**: Nutzer können nachvollziehen, ob angezeigte Werte aus Cache oder Live-Abruf stammen (z. B. „Stand: . . . “).

3.4 Fehlerzustände & Systemmeldungen

3.4.1 Implementierung einheitlicher und verständlicher Fehlermeldungen.

Erfüllungskriterien:

- **EK-3.4.1.1**: Fehlermeldungen sind konsistent strukturiert (Titel, Ursache, Handlungsempfehlung) und fachlich verständlich.
- **EK-3.4.1.2**: Fehlertexte vermeiden interne Details (Stacktraces, IDs) und sind dennoch informativ genug für Nutzerentscheidungen.
- **EK-3.4.1.3**: Wiederkehrende Fehlerzustände sind einheitlich klassifiziert (z. B. Netzwerkfehler vs. Validierungsfehler) und UI-seitig gleich behandelt.

3.4.2 Trennung von nutzerrelevanten Informationen und internen Systemdetails.

Erfüllungskriterien:

- **EK-3.4.2.1**: Nutzer sieht nur notwendige Informationen; interne Diagnosedaten werden serverseitig geloggt, nicht in der UI angezeigt.
- **EK-3.4.2.2**: Meldungen enthalten klare nächste Schritte (Retry, Kontakt, alternative Aktion), ohne Debug-Informationen preiszugeben.
- **EK-3.4.2.3**: Bei Support-Fällen existiert eine optionale, nicht-sensitive Referenz (z. B. Fehlercode), die eine Nachverfolgung ermöglicht.

3.4.3 Kontextbezogene Anzeige von Systemmeldungen zur Unterstützung der Nutzerinteraktion.

Erfüllungskriterien:

- **EK-3.4.3.1**: Systemmeldungen erscheinen dort, wo sie entstehen (Inline bei Formularen, global bei Systemzuständen) und sind eindeutig zuordenbar.
- **EK-3.4.3.2**: Meldungen beeinflussen Interaktionen korrekt (z. B. Deaktivierung Submit bei Fehlern, Wiederholbarkeit bei Retry).
- **EK-3.4.3.3**: Meldungen verschwinden kontrolliert (z. B. nach Erfolg, nach Timeout, manuell schließbar), ohne „hängende“ Zustände.

3.5 Bestätigungs- & Hinweisstufen

3.5.1 Umsetzung von Bestätigungsmechanismen vor potenziell kritischen Nutzeraktionen.

Erfüllungskriterien:

- **EK-3.5.1.1**: Kritische Aktionen (z. B. Löschen, irreversible Änderungen) erfordern eine explizite Bestätigung (Dialog/Second-Step).
- **EK-3.5.1.2**: Bestätigungsdialoge enthalten klare Konsequenzbeschreibung und eindeutige Aktionen (Primär/Abbrechen).
- **EK-3.5.1.3**: Abbruch führt zu keinem Seiteneffekt; Bestätigung führt deterministisch zur Aktion und bestätigt Erfolg oder Fehler.

3.5.2 Definition und Implementierung unterschiedlicher Hinweisstufen.

Erfüllungskriterien:

- **EK-3.5.2.1**: Es existieren definierte Hinweisstufen (z. B. Info, Warnung, kritisch) mit konsistenter visueller Codierung.
- **EK-3.5.2.2**: Die Einstufung erfolgt nachvollziehbar nach Regeln (z. B. Datenunsicherheit → Warnung).
- **EK-3.5.2.3**: Hinweisstufen sind UI-weit konsistent (gleiche Stufe → gleiche Bedeutung und Darstellung).

3.5.3 Sicherstellung einer konsistenten Interaktionslogik bei Bestätigungen und Hinweisen.

Erfüllungskriterien:

- **EK-3.5.3.1**: Bestätigungs- und Hinweislogik ist einheitlich implementiert (z. B. zentrale Komponenten/Patterns) und verhindert Sonderfälle.
- **EK-3.5.3.2**: Hinweise beeinflussen Interaktionen konsistent (z. B. Blocking bei kritisch, non-blocking bei Info).
- **EK-3.5.3.3**: Zustände sind testbar und reproduzierbar; identische Aktion erzeugt identische UI-Reaktion.

4 Vertrauen, Transparenz & UX-Security

4.1 Sicherheit & Vertrauen

4.1.1 Darstellung sichtbarer Sicherheitsindikatoren innerhalb der Benutzeroberfläche.

Erfüllungskriterien:

- **EK-4.1.1.1**: Sicherheitsrelevante Zustände (z. B. Login-Status, Rollenrechte, sichere Verbindung) sind sichtbar und korrekt angezeigt.
- **EK-4.1.1.2**: Indikatoren sind konsistent und nicht irreführend (keine „Sicher“-Signale ohne tatsächliche Grundlage).
- **EK-4.1.1.3**: Indikatoren sind barrierearm und erklären ihre Bedeutung bei Bedarf (Tooltip/Info).

4.1.2 Umsetzung konsistenter Rückmeldungen bei sicherheitsrelevanten Aktionen.

Erfüllungskriterien:

- **EK-4.1.2.1**: Sicherheitsrelevante Aktionen (z. B. Passwortänderung, Session-Logout) liefern unmittelbares Feedback (Erfolg/Fehler).
- **EK-4.1.2.2**: Feedback ist eindeutig und enthält notwendige Handlungsempfehlungen (z. B. „Bitte erneut anmelden“).
- **EK-4.1.2.3**: Feedback offenbart keine sensitiven Details (z. B. keine Information, ob Nutzername existiert).

4.1.3 Vermeidung widersprüchlicher oder irreführender UI-Signale im Sicherheitskontext.

Erfüllungskriterien:

- **EK-4.1.3.1**: UI stellt Berechtigungen korrekt dar (z. B. deaktivierte Aktionen bei fehlender Rolle, statt späterer Fehlermeldung).
- **EK-4.1.3.2**: Sicherheitsindikatoren sind über alle Screens konsistent (z. B. gleiche Session-Logik, gleicher Logout-Status).
- **EK-4.1.3.3**: Fehlzustände führen zu klaren, nicht beschönigenden Meldungen (z. B. „Sitzung abgelaufen“ statt stiller Fehler).

4.2 Transparenz sicherheitsrelevanter Aktionen

4.2.1 Anzeige verständlicher Hinweise bei sicherheitsrelevanten Änderungen.

Erfüllungskriterien:

- **EK-4.2.1.1**: Bei sicherheitsrelevanten Änderungen (z. B. Passwort, E-Mail, Rollenänderung) erhält der Nutzer eine verständliche Bestätigung.
- **EK-4.2.1.2**: Hinweise benennen die Änderung und den Zeitpunkt, ohne sensible Inhalte offenzulegen.
- **EK-4.2.1.3**: Hinweise erscheinen zuverlässig und sind nachvollziehbar (z. B. in UI-History/Notifications).

4.2.2 Rückmeldung an Nutzer bei kritischen sicherheitsbezogenen Aktionen.

Erfüllungskriterien:

- **EK-4.2.2.1**: Kritische Aktionen (z. B. Login von neuem Gerät, Logout aller Sessions) sind klar rückgemeldet.
- **EK-4.2.2.2**: Rückmeldungen enthalten Handlungsempfehlungen bei Verdacht (z. B. Passwort ändern, Support kontaktieren).
- **EK-4.2.2.3**: Rückmeldungen sind konsistent und vermeiden Account-Enumeration oder Leaks.

4.2.3 Umsetzung zeitnaher Benachrichtigungen ohne Offenlegung interner Systemdetails.

Erfüllungskriterien:

- **EK-4.2.3.1**: Sicherheitsbenachrichtigungen werden zeitnah ausgelöst und sind für den Nutzer zugänglich (UI/Push/E-Mail je nach System).
- **EK-4.2.3.2**: Inhalte enthalten nur nutzerrelevante Informationen (Was? Wann? Was tun?), keine technischen Interna.
- **EK-4.2.3.3**: Benachrichtigungen sind idempotent (keine Duplikatflut) und zuverlässig (Retry/Queue-Mechanismus, falls vorgesehen).

4.3 Auditierbarkeit aus Nutzersicht

4.3.1 Bereitstellung einer Einsicht in sicherheitsrelevante Nutzeraktionen.

Erfüllungskriterien:

- **EK-4.3.1.1**: Nutzer kann sicherheitsrelevante Aktionen einsehen (z. B. Login, Passwortänderung, Logout, Alert-Änderungen), soweit fachlich vorgesehen.
- **EK-4.3.1.2**: Einträge enthalten mindestens Zeitpunkt, Aktionstyp und Kontext (z. B. Gerät/Session-Info, soweit datenschutzkonform).
- **EK-4.3.1.3**: Die Liste ist vollständig, konsistent und verhindert nachträgliche Manipulation aus Nutzersicht (z. B. keine „verschwindenden“ Einträge).

4.3.2 Zeitliche Einordnung und Nachvollziehbarkeit sicherheitsbezogener Ereignisse.

Erfüllungskriterien:

- **EK-4.3.2.1**: Ereignisse sind chronologisch korrekt und mit konsistentem Zeitformat (Zeitzone/Locale) dargestellt.
- **EK-4.3.2.2**: Filter/Sortierung nach Zeitraum funktioniert korrekt und verändert keine Inhalte (nur Darstellung).
- **EK-4.3.2.3**: Relevante Ereignisse sind durch Such-/Filterkriterien schnell auffindbar (z. B. „Login“, „Passwort“).

4.3.3 Beschränkung der Einsicht auf eigene nutzerbezogene Aktivitäten.

Erfüllungskriterien:

- **EK-4.3.3.1**: Nutzer kann ausschließlich eigene Aktivitäten einsehen; serverseitige Zugriffskontrolle verhindert Fremdzugriff.
- **EK-4.3.3.2**: IDs/Endpunkte sind gegen IDOR abgesichert; Tests mit fremden IDs liefern keine Daten.
- **EK-4.3.3.3**: Fehlerfälle werden korrekt behandelt (z. B. 403/404) und geben keine sensitiven Informationen preis.

4.4 Feature- & Zugriffstransparenz

4.4.1 Darstellung der für den jeweiligen Nutzer freigeschalteten Funktionen.

Erfüllungskriterien:

- **EK-4.4.1.1**: Die UI zeigt nur Funktionen, die für den Nutzer freigeschaltet sind, oder kennzeichnet gesperrte Funktionen eindeutig.
- **EK-4.4.1.2**: Sichtbarkeit und tatsächliche Berechtigungen sind konsistent (keine sichtbare Aktion, die serverseitig regelmäßig scheitert).
- **EK-4.4.1.3**: Änderungen an Rollen/Berechtigungen werden zeitnah in der UI reflektiert (z. B. nach Re-Login/Token-Refresh).

4.4.2 Erläuterung eingeschränkter oder nicht verfügbarer Features.

Erfüllungskriterien:

- **EK-4.4.2.1**: Gesperrte Features sind begründet (z. B. „Benötigt Rolle X“ oder „Feature derzeit nicht aktiviert“).
- **EK-4.4.2.2**: Hinweise sind kurz, verständlich und führen zu einem klaren nächsten Schritt (z. B. Kontakt Admin).
- **EK-4.4.2.3**: Erklärungen offenbaren keine sensiblen Details über Systemkonfiguration oder andere Nutzer.

4.4.3 Konsistente Visualisierung von Berechtigungen und Zugriffsumfängen.

Erfüllungskriterien:

- **EK-4.4.3.1**: Berechtigungen sind UI-weit konsistent visualisiert (z. B. Disabled State, Hinweislabel, Lock-Icon).
- **EK-4.4.3.2**: Zugriffsumfang (z. B. „nur eigene Portfolios“) wird im Kontext klar kommuniziert.
- **EK-4.4.3.3**: Wechsel des Umfangs (z. B. Admin vs. User) führt zu konsistenter UI-Anpassung ohne veraltete Anzeige.

4.5 Personalisierung & Sichtbarkeit von Sicherheitsfunktionen

4.5.1 Umsetzung einer personalisierbaren Anzeige sicherheitsrelevanter Hinweise.

Erfüllungskriterien:

- **EK-4.5.1.1**: Nutzer kann sicherheitsrelevante Hinweise konfigurieren (z. B. Anzeigehäufigkeit, Kanäle), soweit fachlich vorgesehen.
- **EK-4.5.1.2**: Einstellungen werden persistent gespeichert und wirken deterministisch auf die Anzeige.
- **EK-4.5.1.3**: Personalisierung reduziert nicht die Sicherheit (z. B. kritische Warnungen können nicht vollständig unterdrückt werden, falls vorgesehen).

4.5.2 Bereitstellung personalisierter sicherheitsbezogener Benachrichtigungen.

Erfüllungskriterien:

- **EK-4.5.2.1**: Benachrichtigungen berücksichtigen Nutzerpräferenzen (Kanal/Granularität) und bleiben datenschutzkonform.
- **EK-4.5.2.2**: Inhalte sind verständlich und enthalten Handlungsempfehlungen, ohne sensitive Daten zu leaken.
- **EK-4.5.2.3**: Auslieferung ist robust (Retry/Queue), ohne Duplikate oder Benachrichtigungsfluten zu erzeugen.

4.5.3 Implementierung eines sicheren Anmeldeverfahrens für Nutzer.

Erfüllungskriterien:

- **EK-4.5.3.1**: Login nutzt sichere Verfahren (z. B. gehashte Passwörter, TLS, sichere Token/Sessions) und verhindert triviale Angriffe.
- **EK-4.5.3.2**: Fehlermeldungen beim Login sind sicher (keine Account-Enumeration) und dennoch nutzerverständlich.
- **EK-4.5.3.3**: Schutzmaßnahmen gegen Missbrauch sind implementiert (z. B. Rate-Limit, Lockout/Captcha optional), ohne UX unkontrolliert zu verschlechtern.

5 Plattformsicherheit & Zugriffskontrolle

5.1 Authentifizierung

5.1.1 Implementierung eines sicheren Anmeldeverfahrens für Nutzer.

Erfüllungskriterien:

- **EK-5.1.1.1**: Authentifizierung erfolgt über sichere Mechanismen (TLS, Passwort-Hashing, sichere Session/Token-Verwaltung).
- **EK-5.1.1.2**: Login- und Logout-Flows sind gegen typische Angriffe abgesichert (z. B. CSRF, Brute-Force via Rate-Limit).
- **EK-5.1.1.3**: Sicherheitsrelevante Ereignisse (Login, Logout, Fehlversuche) werden protokolliert, ohne Passwörter oder Tokens zu loggen.

5.1.2 Verifikation von Nutzeridentitäten vor dem Zugriff auf personalisierte Funktionen.

Erfüllungskriterien:

- **EK-5.1.2.1**: Personalisierte Endpunkte/Views sind geschützt; Zugriff ohne gültige Authentifizierung wird serverseitig verhindert.
- **EK-5.1.2.2**: Auth-Status wird konsistent geprüft (Middleware/Guards); Umgehungen über alternative Routen sind ausgeschlossen.
- **EK-5.1.2.3**: Abgelaufene Sessions/Tokens werden zuverlässig erkannt und führen zu kontrollierten Re-Auth-Flows.

5.1.3 Absicherung des Authentifizierungsprozesses gegen Missbrauch.

Erfüllungskriterien:

- **EK-5.1.3.1**: Brute-Force und Credential-Stuffing werden durch Schutzmechanismen erschwert (Rate-Limit, Lockout/Backoff).
- **EK-5.1.3.2**: Sensible Daten werden nicht im Client gespeichert (z. B. keine Passwörter, keine Tokens in unsicheren Speichern).
- **EK-5.1.3.3**: Fehlermeldungen sind sicher gestaltet und verhindern Account-Enumeration (gleichartige Response bei falschen Credentials).

5.2 Autorisierung & Rollenmodelle

5.2.1 Umsetzung einer rollenbasierten Zugriffskontrolle.

Erfüllungskriterien:

- **EK-5.2.1.1**: Rollen (z. B. User/Admin) sind definiert und werden serverseitig für Zugriffsentscheidungen verwendet.
- **EK-5.2.1.2**: Unerlaubte Aktionen werden zuverlässig verhindert (403/401), unabhängig von UI-Restriktionen.
- **EK-5.2.1.3**: Rollenprüfungen sind zentral implementiert (Policies/Guards) und vermeiden Duplikation/Inkonsistenzen.

5.2.2 Definition funktions- und datenbezogener Berechtigungen.

Erfüllungskriterien:

- **EK-5.2.2.1**: Berechtigungen sind granular definiert (Funktion + Datenumfang, z. B. „nur eigene Portfolios“).
- **EK-5.2.2.2**: Datenbezogene Berechtigungen verhindern IDOR (z. B. kein Zugriff über fremde IDs/UUIDs).
- **EK-5.2.2.3**: Berechtigungen sind dokumentiert und testbar; Änderungen sind nachvollziehbar versioniert.

5.2.3 Zentrale Durchsetzung der Autorisierungslogik im System.

Erfüllungskriterien:

- **EK-5.2.3.1**: Autorisierung wird serverseitig zentral erzwungen (Middleware/Policies), nicht nur im Frontend.
- **EK-5.2.3.2**: Alle relevanten Endpunkte sind abgedeckt; „vergessene“ Routen ohne Autorisierung existieren nicht.
- **EK-5.2.3.3**: Logging/Monitoring erfasst unautorisierte Zugriffsversuche nachvollziehbar, ohne sensible Inhalte zu protokollieren.

5.3 Sitzungs- & Zugriffssicherheit

5.3.1 Implementierung einer sicheren Verwaltung aktiver Sitzungen.

Erfüllungskriterien:

- **EK-5.3.1.1**: Sessions/Tokens werden sicher erzeugt, gespeichert und übertragen (Secure/HttpOnly Cookies oder sichere Token-Strategie).
- **EK-5.3.1.2**: Session-Fixation und Token-Reuse werden verhindert (z. B. Rotation nach Login/privilegierten Aktionen).
- **EK-5.3.1.3**: Aktive Sessions können serverseitig invalidiert werden (z. B. Logout, Logout-all), ohne Restzugriffe.

5.3.2 Zeitliche Begrenzung von Zugriffen auf personalisierte Funktionen.

Erfüllungskriterien:

- **EK-5.3.2.1**: Sessions/Tokens haben definierte Ablaufzeiten (Idle/Absolute) und werden zuverlässig durchgesetzt.
- **EK-5.3.2.2**: Ablauf führt zu kontrollierten UI- und API-Reaktionen (Re-Login), ohne unklare Fehlerbilder.
- **EK-5.3.2.3**: Token/Session-Refresh ist sicher (z. B. Refresh-Mechanismus) und verhindert Replay-Angriffe.

5.3.3 Sicherstellung einer kontrollierten und sicheren Beendigung von Sitzungen.

Erfüllungskriterien:

- **EK-5.3.3.1**: Logout invalidiert Session/Tokens serverseitig und entfernt clientseitige Auth-Daten zuverlässig.
- **EK-5.3.3.2**: Nach Logout sind geschützte Ressourcen nicht mehr zugreifbar (auch nicht über Back-Button/Cache).
- **EK-5.3.3.3**: Fehlerfälle beim Logout werden kontrolliert behandelt und führen nicht zu „halb-abgemeldeten“ Zuständen.

5.4 Schnittstellensicherheit

5.4.1 Absicherung interner und externer Programmierschnittstellen.

Erfüllungskriterien:

- **EK-5.4.1.1**: APIs sind durch Authentifizierung/Autorisierung geschützt; öffentliche Endpunkte sind minimal und begründet.
- **EK-5.4.1.2**: Transport- und Sicherheitsheader sind korrekt (TLS, CORS-Policy, ggf. CSP je nach Architektur).
- **EK-5.4.1.3**: Sensitive Operationen sind gegen CSRF/Replay geschützt (je nach Token/Cookie-Strategie).

5.4.2 Validierung eingehender Anfragen vor deren Verarbeitung.

Erfüllungskriterien:

- **EK-5.4.2.1**: Eingaben werden serverseitig validiert (Schema, Typen, Wertebereiche) und fehlerhafte Requests werden kontrolliert abgewiesen (4xx).
- **EK-5.4.2.2**: Validierung verhindert typische Injection-Klassen (SQLi, XSS in Output-Kontexten) durch Sanitization/Encoding/ORM.
- **EK-5.4.2.3**: Validierungsfehler liefern verständliche, aber nicht übermäßig detaillierte Fehlermeldungen.

5.4.3 Kontrolle und Einschränkung zulässiger Schnittstellenoperationen.

Erfüllungskriterien:

- **EK-5.4.3.1**: Erlaubte Methoden/Operationen sind strikt begrenzt (z. B. keine unnötigen Admin-Endpunkte).
- **EK-5.4.3.2**: Rate-Limits und Quotas schützen vor Missbrauch und stabilisieren Betrieb.
- **EK-5.4.3.3**: Fehlerzustände werden kontrolliert behandelt; kein unhandled Exception Leak in Responses.

5.5 Missbrauchs- & Angriffsschutz

5.5.1 Implementierung von Schutzmechanismen gegen automatisierte Angriffe.

Erfüllungskriterien:

- **EK-5.5.1.1**: Automatisierte Angriffe (Brute-Force, Scraping) werden durch Rate-Limits, Backoff und ggf. Captcha-Mechanismen erschwert.
- **EK-5.5.1.2**: Schutzmechanismen sind zielgerichtet, verursachen keine unkontrollierten False Positives und sind konfigurierbar.
- **EK-5.5.1.3**: Ereignisse werden protokolliert und erlauben eine Nachverfolgung ohne sensitive Daten offenzulegen.

5.5.2 Begrenzung ressourcenintensiver oder missbräuchlicher Aktionen.

Erfüllungskriterien:

- **EK-5.5.2.1**: Ressourcenintensive Operationen (z. B. Massenscreening, große Zeitreihenexports) sind durch Limits/Pagination/Async-Patterns kontrolliert.
- **EK-5.5.2.2**: Wiederholte Requests erzeugen keine unkontrollierte Last (Caching, Idempotenz, Debounce im UI).
- **EK-5.5.2.3**: Bei Überschreitung von Limits werden klare Fehlermeldungen geliefert (z. B. 429) und der Systemzustand bleibt konsistent.

5.5.3 Erkennung und Protokollierung auffälliger Nutzungsmuster.

Erfüllungskriterien:

- **EK-5.5.3.1**: Auffällige Muster (z. B. viele Fehlversuche, ungewöhnliche Request-Rate) werden erkannt und klassifiziert.
- **EK-5.5.3.2**: Protokollierung ist nachvollziehbar (Zeit, Nutzer/Session, Aktionstyp) und datenschutzkonform.
- **EK-5.5.3.3**: Detektion kann operational genutzt werden (z. B. Alerts/Dashboards), ohne die Verfügbarkeit zu beeinträchtigen.

5.6 Protokollierung & Sicherheitsüberwachung

5.6.1 Zentrale Erfassung sicherheitsrelevanter Systemereignisse.

Erfüllungskriterien:

- **EK-5.6.1.1**: Sicherheitsrelevante Events (Auth, Rollen, Datenzugriffe, Admin-Aktionen) werden zentral erfasst.
- **EK-5.6.1.2**: Logs sind strukturiert (z. B. JSON/Schema), zeitlich referenziert und ermöglichen Korrelation.
- **EK-5.6.1.3**: Logging enthält keine sensitiven Inhalte (Passwörter, Tokens, personenbezogene Daten ohne Notwendigkeit).

5.6.2 Schutz der Protokolldaten vor Manipulation oder unbefugtem Zugriff.

Erfüllungskriterien:

- **EK-5.6.2.1**: Zugriff auf Logs ist berechtigungsbasiert; nur autorisierte Rollen können Protokolle einsehen.
- **EK-5.6.2.2**: Logs sind gegen Manipulation geschützt (z. B. append-only, zentrale Ablage, Integritätsmechanismen nach Systemdesign).
- **EK-5.6.2.3**: Aufbewahrung/Rotation ist definiert; Protokolle bleiben für definierte Zeiträume verfügbar und nachvollziehbar.

5.6.3 Bereitstellung der Protokolle zur Analyse und Sicherheitsüberwachung.

Erfüllungskriterien:

- **EK-5.6.3.1**: Protokolle können für Analysezwecke gefiltert und ausgewertet werden (z. B. nach Zeit, Eventtyp, Nutzer).
- **EK-5.6.3.2**: Ereignisse sind ausreichend kontextualisiert, um Sicherheitsvorfälle nachzuvollziehen (ohne Datenexzess).
- **EK-5.6.3.3**: Monitoring/Alerting kann auf Logs aufsetzen (z. B. Schwellwerte für Fehlversuche), ohne Systemstabilität zu gefährden.

6 Objektivierter Ergebnisteil

7 Diskussion

8 Ausblick